

NovaTech Solutions Pvt. Ltd.

GDPR Data Protection Policy

Document ID: COMP-GDPR-001

Version: 2.0

Effective Date: January 2026

Prepared By: Data Protection Office

Classification: Internal Use Only

Document Control

Field	Value
Document	GDPR Data Protection Policy
Department	Compliance & Data Protection
Version	2.0
Owner	Data Protection Officer (DPO)
Review Cycle	Annual
Last Updated	January 2026

Table of Contents

1. Introduction
 2. GDPR Policy Statement
 3. Purpose
 4. Scope
 5. Data Protection Principles
 6. Roles and Responsibilities
 7. Categories of Personal Data
 8. Lawful Basis for Processing
-

1. Introduction

NovaTech Solutions Pvt. Ltd. is committed to protecting the privacy and personal data of customers, employees, partners, and other individuals whose information is processed during business operations.

This policy establishes the organization's approach to collecting, processing, storing, sharing, and protecting personal data while promoting transparency, accountability, and responsible data handling.

The policy supports privacy-by-design practices and encourages all personnel to handle personal information responsibly.

2. GDPR Policy Statement

NovaTech processes personal data in a lawful, fair, and transparent manner.

The organization is committed to:

- Protecting personal information.
- Respecting individual privacy rights.
- Limiting data collection to legitimate business purposes.
- Applying appropriate technical and organizational safeguards.
- Supporting accountability throughout the data lifecycle.
- Continuously improving privacy practices.

All employees and authorized third parties handling personal data must comply with this policy.

3. Purpose

The objectives of this policy are to:

- Protect personal data from unauthorized access, disclosure, alteration, or destruction.
- Define responsibilities for data protection.
- Promote consistent privacy practices.
- Support compliance with applicable privacy regulations.
- Reduce privacy-related risks.
- Build trust with customers, employees, and business partners.
- Ensure responsible management of personal information throughout its lifecycle.

4. Scope

This policy applies to:

- Employees
- Contractors
- Consultants
- Temporary staff
- Interns
- Third-party service providers
- Business partners processing personal data on behalf of NovaTech

The policy covers personal data processed through:

- Business applications
- Cloud platforms
- Websites
- Customer portals
- Mobile applications
- Internal systems
- Human Resources systems
- Customer Support systems
- Marketing platforms

The policy applies regardless of whether the information is stored electronically or in physical form.

5. Data Protection Principles

NovaTech follows fundamental principles for responsible processing of personal data.

Lawfulness, Fairness and Transparency

Personal data should be processed lawfully and transparently.

Individuals should be informed about:

- Why their information is collected.
- How it is used.
- Who may access it.
- How long it is retained.

- Their available privacy rights.
-

Purpose Limitation

Personal information should be collected only for specific, legitimate, and documented business purposes.

Information should not be processed for unrelated purposes unless permitted by applicable law.

Data Minimization

Only the minimum amount of personal data necessary for the intended purpose should be collected and processed.

Unnecessary collection of personal information should be avoided.

Accuracy

Reasonable steps should be taken to ensure personal data remains:

- Accurate
- Complete
- Current

Incorrect information should be corrected promptly.

Storage Limitation

Personal information should not be retained longer than necessary for business, contractual, or legal purposes.

Retention periods should be defined within organizational procedures.

Integrity and Confidentiality

Appropriate security measures should protect personal information against:

- Unauthorized access
- Unauthorized disclosure
- Accidental loss
- Alteration
- Destruction

Security controls should reflect the sensitivity of the information being processed.

Accountability

NovaTech is responsible for demonstrating compliance with its privacy obligations through documented policies, procedures, and governance activities.

Privacy responsibilities apply throughout the organization.

6. Roles and Responsibilities

Data protection is a shared organizational responsibility.

Data Protection Officer (DPO)

The Data Protection Officer is responsible for:

- Privacy governance.
 - Data protection guidance.
 - Policy oversight.
 - Privacy risk management.
 - Regulatory coordination.
 - Privacy awareness initiatives.
-

Information Security Team

Responsible for:

- Protecting information systems.
 - Supporting technical security controls.
 - Assisting with security investigations.
 - Monitoring security events affecting personal data.
-

Department Managers

Managers should:

- Ensure privacy procedures are followed.
- Approve appropriate access.
- Support employee training.

- Report privacy concerns promptly.
-

Employees

Employees are responsible for:

- Protecting personal information.
 - Following approved procedures.
 - Accessing only authorized information.
 - Reporting suspected privacy incidents.
 - Completing required privacy training.
-

Third-Party Service Providers

External providers processing personal data should:

- Protect personal information.
 - Follow contractual privacy requirements.
 - Report security incidents promptly.
 - Process information only for approved purposes.
-

7. Categories of Personal Data

NovaTech may process different categories of personal information depending on business activities.

Customer Information

Examples include:

- Name
 - Business email address
 - Telephone number
 - Organization
 - Customer account information
-

Employee Information

Examples include:

- Employee identification number
 - Contact information
 - Employment records
 - Payroll information
 - Emergency contact details
-

Business Contact Information

Examples include:

- Vendor contacts
 - Business partners
 - Procurement representatives
 - Account managers
-

Technical Information

Examples include:

- IP addresses
- Device identifiers
- Browser information
- Authentication logs
- Application usage records

Technical information should be processed only for legitimate operational or security purposes.

Support Information

Customer Support interactions may include:

- Support tickets
- Case history
- Communication records
- Diagnostic information
- Error reports

Support personnel should access only information required to resolve customer requests.

8. Lawful Basis for Processing

Personal data should be processed only when an appropriate legal basis has been identified.

Contractual Necessity

Processing may be necessary to:

- Deliver products or services.
 - Manage customer accounts.
 - Provide technical support.
 - Fulfill contractual obligations.
-

Legal Obligation

Certain information may be processed to satisfy:

- Employment obligations
 - Financial reporting
 - Regulatory compliance
 - Legal requirements
-

Legitimate Business Interests

Processing may support legitimate business activities such as:

- Service improvement
- Information security
- Fraud prevention
- Customer relationship management

Such processing should consider the rights and expectations of affected individuals.

Consent

Where consent is used as the legal basis:

- Consent should be freely given.
- Consent should be informed.

- Consent should be specific.
- Individuals should be able to withdraw consent where appropriate.

Consent records should be maintained when required.

Protection of Vital Interests

Processing may be permitted where necessary to protect the life, health, or safety of an individual.

Such situations are expected to be exceptional.

Revision History

Version	Date	Description
1.0	January 2024	Initial GDPR Data Protection Policy
1.5	July 2025	Added Data Protection Principles and Personal Data Categories
2.0	January 2026	Updated Governance, Lawful Processing, and Privacy Responsibilities

9. Data Collection

Personal data should be collected only when necessary to support legitimate business activities.

The organization should avoid collecting unnecessary or excessive personal information.

Collection Principles

Personal information should be:

- Collected fairly
- Relevant to the intended purpose
- Limited to business requirements
- Obtained through approved processes

Individuals should be informed about why their information is being collected.

Sources of Personal Data

Personal information may be collected through:

- Customer registrations
- Employment processes
- Support requests
- Website forms
- Business contracts
- Marketing activities
- System-generated records

Collection methods should be documented where appropriate.

10. Consent Management

Where processing relies on consent, consent should be managed appropriately.

Consent Requirements

Consent should be:

- Freely given
- Specific
- Informed
- Unambiguous

Individuals should not be pressured into providing consent.

Withdrawal of Consent

Where consent is the lawful basis for processing:

- Individuals should be able to withdraw consent.
 - Withdrawal requests should be processed promptly.
 - Withdrawal should not affect previous lawful processing.
-

Consent Records

Where required, records should include:

- Individual identity
- Date consent was obtained
- Processing purpose
- Consent method
- Withdrawal history

Consent documentation supports accountability.

11. Data Subject Rights

NovaTech respects the privacy rights of individuals whose personal data is processed.

Right to Information

Individuals may request information regarding:

- Categories of personal data processed
- Processing purposes
- Data recipients
- Retention practices

Privacy notices should be clear and understandable.

Right of Access

Individuals may request access to their personal information.

Requests should be handled according to approved procedures.

Identity verification should occur before releasing personal information.

Right to Rectification

Individuals may request correction of inaccurate or incomplete personal information.

Corrections should be completed within organizational procedures.

Right to Erasure

Where applicable, individuals may request deletion of personal information.

Deletion requests should consider:

- Legal obligations
- Contractual requirements
- Business retention needs

Approved deletion activities should be documented.

Right to Restrict Processing

Individuals may request temporary restriction of processing under appropriate circumstances.

Restrictions should be reviewed before removal.

Right to Data Portability

Where applicable, individuals may request a copy of eligible personal information in a structured and commonly used format.

Requests should be processed securely.

Right to Object

Individuals may object to certain types of processing

18. Data Protection Impact Assessments (DPIA)

NovaTech performs Data Protection Impact Assessments (DPIAs) for processing activities that may present elevated privacy risks.

DPIAs help identify, assess, and reduce risks before processing begins.

When a DPIA Should Be Considered

A DPIA should be evaluated for activities involving:

- Large-scale personal data processing
- New technologies
- Automated decision-making
- Sensitive personal information
- Systematic monitoring
- High-risk processing activities

The Data Protection Officer should advise whether a DPIA is required.

DPIA Documentation

A completed assessment should include:

- Description of the processing activity
- Business purpose
- Categories of personal data
- Privacy risks
- Risk mitigation measures
- Residual risks
- Approval information

Assessments should be retained according to document retention procedures.

19. Personal Data Breach Management

NovaTech maintains procedures for identifying, investigating, and responding to personal data breaches.

Prompt response reduces potential impact on affected individuals and the organization.

Examples of Personal Data Breaches

Examples include:

- Unauthorized disclosure
- Accidental deletion
- Lost devices containing personal data
- Misdirected emails
- Unauthorized database access
- Credential compromise
- Improper sharing of personal information

All suspected breaches should be reported immediately.

Breach Response Process

Privacy incidents should follow a structured process:

1. Detection

2. Initial assessment
3. Containment
4. Investigation
5. Risk evaluation
6. Recovery
7. Documentation
8. Lessons learned

The Data Protection Officer coordinates privacy-related investigations with Information Security and affected business units.

20. Training & Awareness

Privacy awareness is essential for protecting personal information.

All personnel handling personal data should understand their responsibilities.

Mandatory Training

Employees should complete training covering:

- GDPR principles
- Personal data handling
- Privacy responsibilities
- Data classification
- Secure information sharing
- Incident reporting
- Data subject rights
- Acceptable use

Training completion should be recorded.

Awareness Activities

Privacy awareness initiatives may include:

- Internal newsletters
- Workshops
- Awareness campaigns

- Policy refresh sessions
- Phishing simulations
- Team discussions

Regular awareness activities strengthen organizational privacy culture.

21. Audits & Compliance Monitoring

NovaTech periodically evaluates privacy controls to ensure continued effectiveness.

Internal Audits

Audits may review:

- Policy compliance
- Personal data processing
- Consent management
- Access controls
- Data retention
- Third-party compliance
- Privacy documentation

Audit findings should be documented and tracked until resolved.

Compliance Monitoring

Ongoing monitoring may include:

- Policy reviews
- Processing activity reviews
- Privacy metrics
- Security monitoring
- Vendor assessments

Monitoring helps identify opportunities for improvement.

22. Record Keeping

NovaTech maintains records supporting privacy governance and accountability.

Processing Records

Records may include:

- Processing purpose
- Categories of personal data
- Data recipients
- Retention periods
- Security controls
- Responsible department

Records should be maintained accurately and reviewed periodically.

Privacy Documentation

Examples include:

- Privacy notices
- Consent records
- DPIAs
- Breach reports
- Training records
- Audit reports
- Policy acknowledgements

Documentation supports operational consistency and regulatory readiness.

23. Policy Exceptions

Exceptions